

Password and Authentication Policy

Nimbus Analytics Inc. -- Security Department

Effective Date: January 10, 2026

1. Purpose

This policy defines minimum password and authentication requirements for all systems accessing Nimbus Analytics infrastructure, applicable to employees, contractors, and service accounts.

2. Password Requirements

All user passwords must be a minimum of 14 characters, contain at least one uppercase letter, one lowercase letter, one number, and one special character. Passwords must not match any of the user's previous 10 passwords and must not appear in the company's breached-password blocklist, which is checked automatically at creation time via Okta.

3. Multi-Factor Authentication

Multi-factor authentication (MFA) is mandatory for all accounts accessing production systems, VPN, and the corporate email platform. Approved MFA methods are: authenticator app (preferred), hardware security key, or SMS (permitted only as a fallback, not primary). SMS-only MFA is disabled for any account with access to Tier 1 data as classified in the Data Classification Policy.

4. Password Rotation

Standard user account passwords do not expire on a fixed schedule, per current NIST guidance, but must be rotated immediately if a compromise is suspected or confirmed. Service account credentials and API keys must be rotated at least every 90 days, tracked in the Access Control Policy's credential inventory.

5. Account Lockout

Accounts are automatically locked after 5 consecutive failed login attempts within a 15-minute window. Locked accounts require identity verification through the IT Service Desk to unlock; self-service unlock is not available for locked accounts as a security control.

6. Shared and Service Accounts

Shared human-use accounts are prohibited. Service accounts used by applications must be registered in the credential vault (HashiCorp Vault) with owner attribution, and direct human login to service accounts is logged and alerted per the Incident Response Policy.

7. Enforcement

Violations of this policy, including password sharing or MFA bypass attempts, are handled under the disciplinary process described in the Employee Handbook and may result in immediate access revocation pending investigation.

8. Contact

Questions should be directed to security-policy@nimbusanalytics.example.